

資訊安全期末考

問答題 (100%,每題 7 分,共 13 題, 其中一題為 9 分)

1. (A) 圖 8-9 資料庫稽核：分析網路封包 請敘述優缺點？缺點如何改進，提示使用在增加一條網路線。

Answer：省略。

2. (B) 圖 8-10 資料庫稽核：安裝代理軟體請敘述優缺點？缺點如何改進，試圖解決資料隱碼攻擊方法(不在資料庫內做的方法)

Answer：省略。

3. 什麼是『交叉錯誤率』（Crossover Error Rate；CER）？其值交叉點高或低有何差別。

Answer：

在生物資訊認證中，將設備有效的敏感度調整至錯誤拒絕率與錯誤接受率之交叉點，稱為『交叉錯誤率』（Crossover Error Rate；CER）。

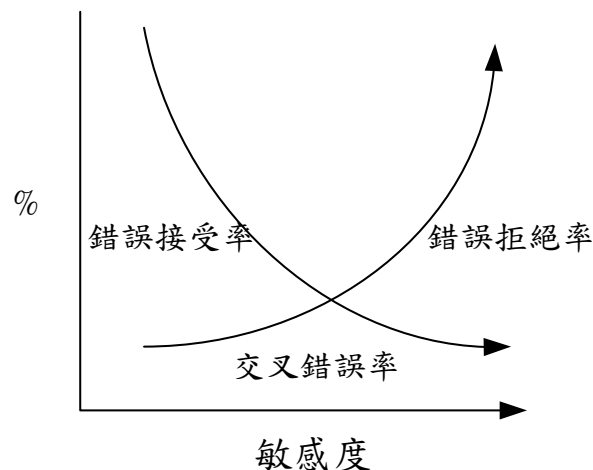


圖 9-3 錯誤率與敏感度關係圖

4. 什麼是 TCP SYN Flood 攻擊？

Answer: TCP SYN Flood 攻擊，是利用三向交握的弱點，惡意地送出許多 TCP SYN 封包，但後續卻沒有回覆確認(ACK)封包。伺服器端會等待使用者端的回應，累積很多等待回應的程式，使伺服器資源耗盡，直至伺服器無法運作。圖 7-6 表示 TCP SYN Flood 攻擊。

5. 什麼是分散式阻斷服務攻擊(DDoS)？

Answer: DDoS 是 DoS 的一種，攻擊的模式不是一對一，而是以多對一的方式，同時對一個目標發動攻擊，而這些發動攻擊的節點，是已經被入侵而不自知的受控制電腦。由於這種攻擊方式以遠端遙控方式，因此不僅難以防範，追查更是不易。

6. 白箱測試與黑箱測試之差異為何？

Answer：

白箱測試與黑箱測試皆是系統重要的測試，在測試概念、測試要項與測試內容皆不一樣，其主要差異比較如表 11-1。

表 11-1 白箱測試與黑箱測試之差異

測試種類	白箱測試	黑箱測試
測試概念	結構性測試	功能測試
測試要項	檢查特定的條件或迴圈，是否與預期之狀態一致	不合乎規格或功能遺漏、介面錯誤、功能錯誤、資料結構錯誤、啟動或結束錯誤
測試內容	軟體內容仔細檢查	程式輸出與輸入之間的正確性

7. 略舉數項說明 4G LTE 在網路存取方面的安全機制。

Answer:

以下略舉數項說明 4G LTE 在網路存取方面的安全機制：

用戶終端設備存取 4G LTE 無線網路的安全機制：此部份是用戶終端連上 4G LTE 無線網路所做的各種認證，以確保連上網路的用戶皆是合法授權的，其主要採用認證與金鑰協議（Authentication and Key Agreement; AKA）作為認證方法。AKA 用一次性密碼作為認證機制，以確保用戶身份的合法性。

移動轉接（handover）過程的安全機制：移動轉接是指用戶終端在通話過程中從一個基地台覆蓋區移動到另一個基地台覆蓋區的過程。此部份需考量網內、網外、或是與非 3GPP 做移動轉接之安全考量，主要仍以彼此之間的金鑰交換與管理作為主要的認證基礎。

IMS 存取安全機制：IMS 代表 IP 多媒體子系統（IP multimedia subsystem; IMS）是 4G 提供 IP 協定的多媒體服務平台，例如，語音、多媒體、與資料等。用戶終端使用在 UICC 卡內的 ISIM 模組（IMS Subscriber Identity Module）作為與 CSCF（Call Service Control Functions）認證的媒介。所有用戶需要通過 LTE 及 IMS 的認證程序才能順利使用 IMS 的多媒體服務。

8. 簡述分享金鑰認證（Share Key Authentication）模式？

Answer：工作站送出認證資訊（Authentication frame）要求對方認證，認證者回應 Challenge Text 給工作站，工作站送出加密 Challenge Text，認證者解密 Challenge Text，回應認證成功與否。

9. 請敘述 IC 卡的攻擊類型。

Answer :

IC 卡的攻擊依形態包含實體攻擊與邏輯攻擊。

實體攻擊

直接存取內部元件(包括處理器，匯流排，記憶體等)，使用微探針(或探測器)進行探測、觀察，以操作或干擾對模組或晶片動手腳，分析及鑑別系統元件和它們之間的交互關係。亦可使用紫外線、X-射線、雷射、電磁場、區域加熱、或光學技術等，誘導錯誤發生以改變它的內容值。

邏輯性攻擊

是一種非侵略性的攻擊，對模組裝置沒有實體損壞。可採用相關設備收集電磁輻射等訊號以重建資料。亦可利用執行加解密運算所耗費之時間特徵，以推導出私密金鑰等攻擊方法。

10. CryptoAPI 密碼模組架構為何？

Answer : CryptoAPI 高階介面提供應用程式一個簡單而多功能的密碼介面；對於應用程式而言，它像是一個黑盒子 (Black Box) 一般，應用程式設計人員不需要了解下層程式之運作，僅需呼叫使用 CryptoAPI，即可產出所需要的結果。應用程式層的下一層是程式庫與作業系統層，最底層為密碼服務提供模組層 (Cryptographic Service Provider ; CSP)，各廠商可以依據規範介面，提供密碼模組掛載在 Windows 作業系統，以便提供給應用程式層的各種應用程式使用。

10. PKCS#11 資料、金鑰與憑證物件組織為何？

Answer : 其組織如下圖。圖中物件之下分為資料、金鑰與憑證物件，金鑰物件以下又分為公開金鑰 (Public Key)、私密金鑰 (Private Key) 與秘密金鑰 (Secret Key)。公開金鑰與私密金鑰在物件中可以標示成金鑰對，秘密金鑰用於對稱式密碼模組的運算。

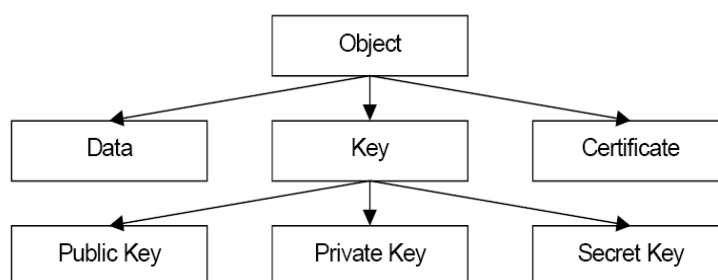


圖 17-7 資料、金鑰與憑證物件組織

11. 防火牆管理的要點是什麼？

Answer : 防火牆之管理原則，需要符合資訊安全三原則—機密性、完整性與可

用性，並要顧及管理層面、技術層面與實體層面，作整體考量。

12. 請敘述 IC 卡的攻擊類型與八個接觸點有哪些關聯性？

Answer：

IC 卡的攻擊依形態包含實體攻擊與邏輯攻擊。

● 實體攻擊

直接存取內部元件(包括處理器，匯流排，記憶體等)，使用微探針(或探測器)進行探測、觀察，以操作或干擾對模組或晶片動手腳，分析及鑑別系統元件和它們之間的交互關係。亦可使用紫外線、X-射線、雷射、電磁場、區域加熱、或光學技術等，誘導錯誤發生以改變它的內容值。系統亂重置，時鐘脈衝接地或不對稱的時脈燒錄程式電源不穩 I/O 輸入錯誤 HIGH 或 LOW

● 邏輯性攻擊

是一種非侵略性的攻擊，對模組裝置沒有實體損壞。可採用相關設備收集電磁輻射等訊號以重建資料。亦可利用執行加解密運算所耗費之時間特徵，以推導出私密金鑰等攻擊方法。不給電源或電壓不穩，，燒錄程式電源不對，I/O 輸入錯誤資料或輸出接地或輸出接電源

接觸點編號	接觸點名稱	接觸點功能
C1	VCC	電源
C2	RTS	重置
C3	CLK	時鐘脈衝
C4	RFU	保留
C5	GND	接地
C6	VPP	燒錄程式電源
C7	I/O	輸入/輸出
C8	RFU	保留

13. 請分別針對下列 4 個演算法其(a)運作原理(b)特色？

- [1] 對稱式加密 (Symmetric-key Cryptography)
- [2] 非對稱式加密 (Asymmetric-key Cryptography)
- [3] 雜湊函數 (Hash Functions)
- [4] 金鑰交換協議 (Key Exchange Algorithms)

Answer:

對稱式加密 (Symmetric-key Cryptography)

運作原理： 加密和解密使用「同一把」金鑰。

特色： 運算速度極快，適合用來加密大量資料（如硬碟加密、檔案傳輸）。缺點是雙方必須先安全地共享這把金鑰。

AES（進階加密標準）： 目前全球最普及、最安全的對稱式加密標準（常見長度有 AES-128, AES-192, AES-256）。美國政府與各大企業皆廣泛使用。

ChaCha20： 一種現代的「串流加密法」，在沒有硬體加速的裝置（如舊手機或物聯網設備）上，運算速度比 AES 更快且非常安全，常與 Poly1305 認證碼搭配使用。

DES / 3DES（資料加密標準）： 歷史悠久的演算法。DES 已被破解，3DES 雖然加強了安全性，但運算太慢且已被淘汰，目前僅在少數舊型金融系統中還能見到。

2. 非對稱式加密 (Asymmetric-key Cryptography)

運作原理： 使用一對金鑰：「公鑰 (Public Key)」與「私鑰 (Private Key)」。公鑰可以公開給所有人用來加密，但只有持有私鑰的人才能解密。

特色： 解決了金鑰傳遞的安全問題，但運算速度極慢。實務上通常用來「加密對稱式金鑰」或進行「數位簽章」。

RSA： 最知名且歷史最悠久的非對稱演算法，安全性建立在「大質數質因數分解」的數學難題上。

ECC（橢圓曲線密碼學）： 現代應用的主流。它的安全性建立在橢圓曲線的離散對數問題上。最大的優勢是用極短的金鑰就能達到與 RSA 相同的安全性（例如 256 位元的 ECC 安全度等同於 3072 位元的 RSA），大幅降低了運算與儲存成本。

3. 雜湊函數 (Hash Functions)

運作原理： 是一種「單向」的數學轉換。無論輸入多大的檔案，都會輸出一串固定長度的亂碼（雜湊值）。

特色： 無法解密反推。只要檔案更改了哪怕一個位元，輸出的雜湊值也會完全不同。常用於儲存密碼（如網站不存明文密碼，只存雜湊值）與驗證檔案完整性。

SHA-2（如 SHA-256, SHA-512）： 目前業界的標準，比特幣的區塊鏈也是使用 SHA-256。

SHA-3： 最新一代的標準，內部結構與 SHA-2 完全不同，作為備用安全標準以防 SHA-2 未來被破解。

MD5 / SHA-1： 曾經非常流行，但目前已被證明在密碼學上不安全（容易發生碰撞），強烈建議不再用於安全防護，僅可用於無關資安的檔案完整性校驗。

4. 金鑰交換協議 (Key Exchange Algorithms)

運作原理： 允許通訊雙方在「不安全的公開網路」上，共同運算出一把只有雙方知道的對稱式金鑰。

DH (Diffie-Hellman)： 最基礎的金鑰交換演算法。

ECDH (Elliptic-Curve Diffie-Hellman)： 基於橢圓曲線版本的 DH，是目前 HTTPS/TLS 安全連線建立時的主流標準。

14. 內部人員與外部人員造成資安事件威脅的比例為何？

Answer：

- 內部人員 80%
- 外部人員 5%

14. 在物聯網的時代，舉例說明可以有哪些智慧型的應用範例？

Answer：

在物聯網的時代，我們將可以發現各種智慧型的應用範例：冰箱故障時會自動發出維修請求訊息——『我們家冰箱溫度飆高，要不要找人來修理?』；瓦斯桶，會對你說：『我們沒有瓦斯了，向瓦斯行訂購一桶瓦斯嗎?』；油管檢測系統發現漏油時，感測器會發出警示訊號，以避免發生意外事件；在大都會地區的通勤族，配備智慧廚房家電的公寓可在主人踏入公寓大門的同時已準備好美味的料理；在老年人口眾多的地區，年長者配戴健康監視器，當發生各種緊急狀況時，裝置就能自動發送緊急救援訊號給醫院。